

DOSSIER TECHNIQUE - PROJET 1 : ARCHITECTURE RÉSEAU PÉRIMÉTRIQUE ET DÉPLOIEMENT D'UNE APPLICATION N-TIER SÉCURISÉE (M2L)

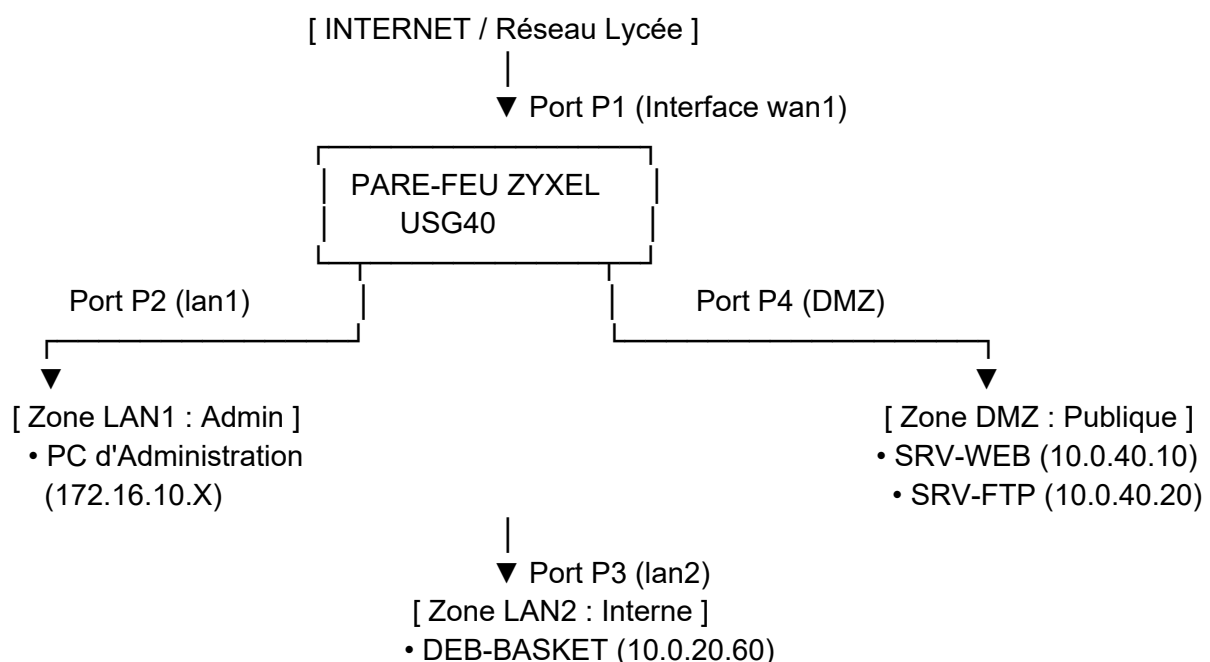
1. Contexte, Tenants et Aboutissants

Ce projet formalise la conception, le déploiement et le durcissement d'une infrastructure réseau et applicative pour la Maison des Ligues de Lorraine (M2L). L'objectif premier est de fournir un environnement de production hautement sécurisé pour la gestion des clubs (notamment la ligue de Basket), en isolant les serveurs exposés à Internet des bases de données critiques.

Pour répondre aux exigences de sécurité sans complexifier l'infrastructure, le choix d'ingénierie s'est porté sur une **sécurisation par zones étanches (Zone-Based Security)** adossée aux ports et interfaces physiques du pare-feu central. Tout mécanisme de virtualisation logique (VLAN) a été écarté pour éliminer les risques de fuites inter-VLAN et garantir un cloisonnement matériel strict et auditable par le jury.

2. Architecture Réseau et Sécurité Périmétrique

L'infrastructure est virtualisée sur un nœud d'hypervision **Proxmox VE (PVE-labo-0C)** via des conteneurs Linux isolés (**LXC Debian 12**). Le cœur de réseau, le routage inter-zone et la sécurité périphérique sont pilotés par un pare-feu matériel **Zyxel USG40**.



A. Plan d'Adressage IP et Cartographie des Ports Physiques

Afin d'éviter tout conflit sur le réseau du laboratoire, les adresses IP se terminant par **.1**, **.50**, **.100** et **.200** ont été formellement exclues de la configuration.

- **Port P1 - Interface wan1 (Zone WAN)** : IP **192.168.193.122/24** (Passerelle d'accès extérieure de l'école).
- **Port P2 - Interface lan1 (Zone LAN1 - Administration)** : IP **172.16.10.254/24** (Dédié au poste de gestion physique **ADDR_ADMIN**).
- **Port P3 - Interface lan2 (Zone LAN2 - Interne Privée)** : IP **10.0.20.254/24** (Segment isolé abritant le serveur de base de données backend **DEB-BASKET** : **10.0.20.60**).
- **Port P4 - Interface DMZ (Zone DMZ - Exposée)** : IP **10.0.40.254/24** (Segment démilitarisé abritant le serveur web **SRV-WEB** : **10.0.40.10** et le serveur de stockage **SRV-FTP** : **10.0.40.20**).

B. Matrice de Filtrage Péri-métrique (Policy Control)

Les trames traversent les règles du Zykel de haut en bas (*First-Match*) avec une clause implicite de rejet par défaut (*Deny All*) :

Priorité	Nom de la Règle	Zone Source	Zone Dest.	Service / Port	Action / Justification
1	BLOCK_LIGUES_VERS_ADMIN	LAN2 (Lignes)	LAN1 (Admin)	ANY	DENY - Isolation totale de la zone d'administration.
2	LIGUES_VERS_DMZ	LAN2 (Lignes)	DMZ	HTTP, HTTPS, FTP	ALLOW - Permet aux machines internes de requêter la DMZ.

3	Allow_Web_to_DB	DMZ (SRV-WEB)	LAN2 (DEB-BASKET)	MySQL_3306 (TCP 3306)	ALLOW - Micro-segmentation applicative. Flux ICMP (Ping) bloqué.
4	SFTP_PORT22	WAN	DMZ (SRV-FTP)	SSH (TCP 22)	ALLOW - Autorise le canal de téléversement externe sécurisé.
5	Block_WAN_to_DMZ	WAN	DMZ	ANY	DENY - Règle implicite de fermeture périphérique.

Sauvegarde NVR : Pour pérenniser cette topologie lors du transfert physique du matériel vers la baie de brassage, la configuration active a été enregistrée dans la mémoire morte non volatile de l'USG40 ([startup-config.conf](#)).

3. Architecture Applicative 3-Tiers et Sécurité Web

Le service métier de gestion des clubs sportifs applique le principe du *Security by Design* réparti sur trois niveaux étanches :

1. **Tier Présentation (Client Externe)** : Le navigateur client interroge l'IP extérieure du pare-feu sur le port public personnalisé [8080](#). Le Zykel applique une règle de translation (PAT / Virtual Server) pour rediriger ce flux vers le port standard [80](#) de [SRV-WEB](#) en DMZ.
2. **Tier Application (SRV-WEB - DMZ)** : Serveur Apache exécutant le portail dynamique en PHP. La liaison sécurisée avec le backend est assurée par l'extension d'abstraction **PDO (PHP Data Objects)**.
3. **Tier Données (DEB-BASKET - LAN2)** : Instance MariaDB (v10.11) hébergeant la base de données de production [m2l_data](#) et la table [clubs](#) (contenant les enregistrements simulés *SLUC Nancy* et *Metz Canonnières*). L'écoute réseau est ouverte sur toutes les interfaces via la directive [bind-address = 0.0.0.0](#) dans le fichier [/etc/mysql/mariadb.conf.d/50-server.cnf](#).

Durcissement Sécuritaire du Portail Web ([index.php](#))

- **Injections SQL** : Éliminées à la racine grâce à l'utilisation exclusive de **requêtes préparées PDO** lors des requêtes d'affichage et d'administration.
- **Cryptage des Mots de Passe** : Les accès stockés dans la table **users** font l'objet d'un hachage irréversible à l'aide de l'algorithme robuste **Bcrypt**.
- **Sessions** : L'accès aux formulaires de gestion CRUD (Bootstrap 5) est protégé par une page d'authentification stricte avec contrôle rigoureux des jetons de sessions PHP.

4. Plateforme de Téléversement Sécurisée (SFTP) et Protection Active

Le serveur **SRV-FTP (10.0.40.20)** gère le dépôt des documents lourds et des codes sources.

- **Migration SFTP** : Pour pallier l'absence de chiffrement du FTP traditionnel (vsftpd configuré initialement avec compte **root** banni via **/etc/ftpusers**), le service a migré vers **SFTP (SSH File Transfer Protocol)**.
- **Translation et NAT-Loopback** : Pour éviter les conflits avec le port SSH d'administration du pare-feu, le Zykel écoute sur le port externe **2222** et translate le flux vers le port interne standard **22** de **SRV-FTP**. L'adresse IP WAN (**192.168.193.122**) a été injectée dans le champ *Original IP* de la règle pour valider le bouclage réseau (**NAT-Loopback**).
- **Cloisonnement des Droits (chmod 700)** : Pour étanchéifier les espaces de stockage des développeurs (**dev-web**) et des ligues (**resp-basket**), les comptes ont été confinés à leur répertoire personnel avec réattribution de propriété exclusive :

```
useradd -m -s /bin/bash dev-web
useradd -m -s /bin/bash resp-basket
chmod 700 /home/dev-web
chmod 700 /home/resp-basket
chown -R dev-web:dev-web /home/dev-web/
chown -R resp-basket:resp-basket /home/resp-basket/
```

- **Défense Active (Fail2Ban Express)** : Installation de Fail2Ban en surveillance sur **/var/log/auth.log**. Pour la démonstration devant le jury, la prison SSH a été configurée en mode express dans **/etc/fail2ban/jail.local** :

```
[DEFAULT]
bantime = 30s ; Temps de blocage court adapté au temps de l'épreuve
findtime = 10m ; Fenêtre d'analyse des échecs
maxretry = 3 ; Bannissement par iptables dès le 4ème échec
```

5. Runbook de Résolution d'Incidents (Projet 1)

Incident Majeur : Erreur SQL 1130 (Échec d'Interconnexion Application/Données)

- **Symptôme** : Le serveur **SRV-WEB** renvoyait une erreur de connexion fatale lors des requêtes PDO vers MariaDB ("*Host is not allowed to connect to this MariaDB server*").
- **Diagnostic** : L'analyse des trames a révélé que le Zyxel USG40 appliquait un masquage d'adresse source (**Source NAT / SNAT**) lors du routage inter-zone de la DMZ vers le LAN2. Les requêtes n'arrivaient pas sur MariaDB avec l'IP réelle de **SRV-WEB** (10.0.40.10) mais avec l'IP de la patte passerelle LAN2 du pare-feu (10.0.20.254).
- **Résolution** : Adaptation des privilèges d'accès directement dans le moteur SQL de production pour autoriser cette adresse translatée :

```
GRANT ALL PRIVILEGES ON m2l_data.* TO 'm2l_admin'@'10.0.20.254' IDENTIFIED BY 'm2l_password';
```

-

Incident Mineur : Erreur "No Route to Host" sur les Mises à Jour Systèmes

- **Symptôme** : Impossible d'exécuter un **apt update** ou d'installer des paquets sur les conteneurs Proxmox.
- **Diagnostic** : Bien que le proxy d'authentification de l'établissement fût configuré dans le fichier **.bashrc** (<http://bthiery:aud3n@192.168.3.2:3128/>), le pare-feu Zyxel ne possédait pas de route statique pour joindre le sous-réseau de ce proxy.
- **Résolution** : Injection dans la table de routage de l'USG40 d'une route statique explicite dirigeant le trafic vers la passerelle générale de l'école (192.168.193.1).

6. Protocole de Recette et Référentiel des Accès

Script de Validation Pratique pour l'Oral

1. **Validation n-Tier** : Ouvrir le site <http://192.168.193.122:8080/index.php> depuis le poste d'administration. Montrer que l'application PHP en DMZ extrait proprement les données de MariaDB située en LAN2, prouvant l'interconnexion.
2. **Validation du Cloisonnement** : Se connecter via WinSCP sur le port 2222 avec le compte **dev-web**. Tenter de double-cliquer ou de lister le dossier **/home/resp-basket**. Constater le blocage immédiat par le message "*Permission denied*".
3. **Validation Fail2Ban** : Taper volontairement 3 mauvais mots de passe sur WinSCP. À la 4ème tentative, montrer que la fenêtre d'authentification se fige (IP bannie par iptables). Attendre 30 secondes, relancer la connexion avec le bon mot de passe : la session s'ouvre, validant l'auto-remédiation.

Référentiel des Secrets (Projet 1)

- **Interface Pare-feu Zyxel** : 192.168.193.117 ou 10.0.10.254 | admin / admin1234
- **Console Hyperviseur Proxmox VE** : <https://192.168.193.113:8006> | bthiery / debian10 (PAM: root / debian)
- **Portail Privé M2L (Web)** : <http://192.168.193.122:8080/index.php> | admin / m2l2026

- **Accès Base MariaDB Métier** : Utilisateur : `m2l_admin` | Mot de passe : `m2l_password`
- **Comptes SFTP WinSCP (Port 2222)** : `dev-web` / `dev-web` et `resp-basket` / `resp-basket`
- **Compte FTP Classique (Port 21)** : `m2l` / `m2l`
- **Proxy d'Établissement Lycée** : Utilisateur : `bthiery` | Mot de passe : `aud3n` | IP : `192.168.3.2:3128`